

Evrensel Uygulama Geliştirme, Merkezi Sır Yönetimi ve ESP32 Yapay Zekâ Ürünleri için Uçtan Uca Rapor

Kapsam, kısıtlar ve veri erişimi

Bu rapor; çok platformlu/evrensel bir uygulamayı “dil bağımsız” (language-agnostic) bir mimariyle nasıl tasarlayıp geliştirebileceğini, özellikle kimlik/sır (secret) yönetimini tüm sistemlerin üzerinde tek noktadan nasıl yöneteceğini ve ayrıca ESP32 ile yapay zekâ tabanlı, insan hayatına dokunan üç ürün fikrini proje seviyesinde (dizin, modüller, akışlar) nasıl kurgulayacağını anlatır.

Kısıt/Not: Hetzner ile ilgili hiçbir öneri veya teklif içermemektedir.

Veri erişimi: “arama geçmişi / kişisel veri kayıtların” gibi kişisel materyallerine doğrudan erişimim yok; bağlı çalışma alanlarında (Slack/Notion/Drive) yaptığım aramalarda da içerik bulunamadı. Bu nedenle rapor; senin belirttiğin araç setine göre evrensel bir “kurulum standardı + uygulanabilir proje iskeleti” yaklaşımıdır.

Evrensel uygulama geliştirmenin çekirdeği

Dil bağımsız mimari ve “config”in doğru ayrıştırılması

Evrensellik (portable/taşınabilirlik) için temel prensip: **aynı kod tabanı**, farklı “deploy” ortamlarında yalnızca **config** değişerek çalışabilmelidir. “Config”, dağıtımdan dağıtımına değişen her şeydir (DB bağlantısı, dış servis kimlik bilgileri, canonical host, API anahtarları vb.). Bu yaklaşım; kod ile config’in sıkı ayrışmasını ister. ¹

Bu noktada env (environment variables) standart ve dil/OS bağımsız bir taşıma mekanizmasıdır; config’i koda gömmenin önüne geçer. ¹ Ancak pratikte env yaklaşımının da riskleri vardır: süreç içinde **parsed edilmeden ham string** gibi kullanılması, “her yerden erişilebilir/global” olması gibi nedenle, iyi pratik; env değerlerini **başlangıçta tek kez parse edip** uygulama içinde typed bir yapı olarak kullanmaktır. ²

Ayrıca “env=dev/stage/prod” gibi “ortam gruplama” yaklaşımı büyüdükçe kombinatorial karmaşa oluşturabilir; bu yüzden config’in parçalı (granular) ve dağıtım bazlı yönetilmesi daha ölçeklenebilir kabul edilir. ¹

Contract-first: çok dilli ekiplerin ortak dili

Diller arası tutarlılık için **contract-first** yaklaşımı, “servis kontratı”nı koddan önce tanımlar:

- HTTP/REST tarafında `Entity["organization","OpenAPI Initiative"],"openapi standard body"]` **OpenAPI Specification**, API yaşam döngüsü boyunca (tasarım, test, dokümantasyon, client üretimi) ortak bir tanım verir; programlama diline bağlı değildir. ³

- RPC/streaming ihtiyacı varsa gRPC + Protobuf yaklaşımı; servis kontratını `.proto` ile tanımlar. Protobuf, dil ve platform nötr bir serileştirme mekanizmasıdır. ⁴

Bu iki yaklaşım; “Java backend”, “TypeScript client”, “Python servis”, “mobil uygulama” gibi farklı dilleri aynı ürün çatısı altında **tek sözleşme** üzerinden hizalar.

Sıfır güven ve en az ayrıcalık ilkesi

Kimlik/sır yönetiminde temel güvenlik prensibi, `entity["organization","NIST","us standards agency"]` **NIST** tanımına göre “en az ayrıcalık”tır: her kullanıcı/iş yükü sadece görevi için gereken minimum yetkiyi alır. ⁵ Bu ilke rapordaki tüm Key Vault/RBAC tasarımının merkezindedir.

Java örneği üzerinden çok dilli proje düzeni

Java proje dizini (Maven standardı)

Java dünyasında “düzen” denince en yaygın ortak zemin Maven’in standart dizin yapısıdır; yeni bir projeye giren geliştirici, `src/main/java`, `src/test/java`, `src/main/resources` gibi klasörleri görmeyi bekler. ⁶ Bu düzen; ekipler arası tutarlılık ve hızlı onboarding sağlar. ⁶

Örnek (konsept) dizin:

- `pom.xml`
- `src/main/java/...` (uygulama kodu)
- `src/main/resources/...` (konfig, i18n dosyaları, şablonlar vb.)
- `src/test/java/...` ve `src/test/resources/...` (testler) ⁶

Bu yapı; monorepo içinde Java servislerini ayrı modüller olarak taşımaya da kolaylaştırır (ör. `services/auth-service-java/`).

Java’da “config yönetimi” (Spring Boot örneğiyle)

Spring Boot; config’i dışsallaştırmak için çok kaynaklı bir model sunar: `application.properties/yml`, environment variables, command-line args vb. ⁷ Ayrıca OS env değişkenlerinin isim kısıtları nedeniyle `.` yerine `_` gibi dönüşümleri önerir (ör. `SPRING_CONFIG_NAME`). ⁷

Bu pratik, 12-factor’ın “config kodda değil dışarıda” ilkesini Java dünyasında doğrudan uygulanabilir hale getirir. ⁸

Çok dilli monorepo’da önerilen ayırım

Evrensel (çok dil + çok platform) bir ürün için sürdürülebilir ayırım:

- **Domain/Contracts:** OpenAPI / Protobuf kontratları (tek kaynak doğruluk) ⁹
- **Backend servisleri:** Java / Python / Node gibi dillerle yazılmış bağımsız servisler
- **Client katmanları:** web/mobil/desktop (gerekirse)
- **Shared libs:** ortak tipler/validasyon (ör. JSON Schema ile payload doğrulama) — JSON Schema spesifikasyonu ayrı “core/validation” dokümanlarıyla sürer. ¹⁰

Merkezi sır ve kimlik yönetimi: Key Vault + Entra ID + App Configuration uçtan uca süreç

Aşağıdaki bölüm “her platformun anahtarlarını tek yerde topla, ihtiyacı olan sadece ihtiyacı kadar alsın” hedefini; `entity["company","Microsoft","technology company"]` Azure üzerinde “kimlik-öncelikli” (secretless-first) bir mimariyle çözer.

Temel ürün ayrımı: Key Vault neye, App Configuration neye?

En kritik ayrım:

- **Key Vault:** şifreler, tokenlar, bağlantı string’leri gibi **kriptografik sırlar** için optimize edilmiştir; secret değeri string olarak saklanır ve tek bir secret için maksimum boyut 25 KB’dır. ¹¹
- **Key Vault’a config koyma:** IP adresleri, servis isimleri, feature flag’ler gibi **genel konfigürasyon verilerini Key Vault’ta tutma** önerilmez; bunun için **Azure App Configuration** kullanılması özellikle belirtilir. ¹²
- **Azure App Configuration:** config + feature flag için merkezî depo yaklaşımı sağlar; ayrıca Key Vault referanslarını destekler (config yüklerken secret’ı Key Vault’tan resolve edebilir). ¹³

Bu ayrım; “Vault’a her şeyi koyayım” yaklaşımını üretimde daha güvenli ve yönetilebilir hale çevirir. ¹⁴

Kimlik katmanı: Managed Identity ile “secretless” bağlantı

Managed identities; uygulamaların kimlik bilgisi (client secret/cert) yönetme ihtiyacını azaltır: uygulama, Entra üzerinden token alır ve bu sayede downstream servislere erişir. ¹⁵ Microsoft’un “secretless authentication” rehberleri; `DefaultAzureCredential` gibi yaklaşımlarla aynı kodun local ve prod’da farklı auth yöntemleriyle çalışmasına odaklanır. ¹⁶

Yetkilendirme modeli: RBAC zorunlu standardın olsun

Key Vault tarafında Microsoft; **legacy access policies** yerine **Azure RBAC** modelini önerir; legacy modelin güvenlik zafiyetleri ve Privileged Identity Management (PIM) entegrasyonu eksikleri vurgulanır. ¹⁷

RBAC modelinde, “kim erişebilir” kararını “Owner / User Access Administrator” gibi rollerin kontrol etmesi; izin yönetimini daha güvenli hale getirir. ¹⁸

Vault sayısı ve ortam ayrımı

Microsoft’un Key Vault RBAC yönergeleri; **uygulama başına ve ortam başına ayrı vault** yaklaşımını en iyi pratik olarak önerir; rol atamalarını da vault scope’unda tutmayı tavsiye eder. ¹⁹ Ayrıca App Service Key Vault reference dokümanı; ortam ayrımı için ayrı vault’lar ve slot setting yaklaşımını pratikte destekler. ²⁰

Ağ güvenliği: private endpoint + public access kapama

Üretimde Key Vault için public erişimi kapatıp yalnız private endpoint üzerinden erişim sağlama seçeneği dokümanite edilmiştir; public access kapatmadan önce Private Link kurulumunun tamamlanması gerektiği vurgulanır. ²¹

Uçtan uca “kurulum standardı” (başlangıçtan üretime)

Aşağıdaki süreç; “sırlar, sabit config, feature flag, audit, rotation” hepsini uçtan uca kapsar.

Adlandırma ve envanter

- 1) **Uygulama envanteri:** her uygulama/servis için tekil bir `appId` belirle (örn. `bitebimuv-core`, `mutluet-api`, `device-gateway`).
 - 2) **Ortamlar:** `dev`, `staging`, `prod`.
 - 3) **Depolar:** - `kv-{appId}-{env}` : sırlar
- `appconfig-{appId}-{env}` : config + feature flags
- Bu, “kim neyi görüyor?” sorusunu çok sadeleştirir. ²²

Sırların nasıl saklanacağı (format + metadata)

Key Vault secrets best practices: - Çok parçalı credential’ları (user/pass gibi) bağlantı string veya JSON olarak saklama,
- Rotasyon/ownership gibi yönetim bilgisini secret value içine değil **tag** olarak koyma önerilir. ¹²

App Configuration ile config + feature flag yönetimi

App Configuration; feature flag’leri merkezî yönetip uygulama redeploy etmeden davranış değiştirmeyi destekler. ²³ Ayrıca Spring ekosisteminde App Configuration + Key Vault reference entegrasyonu için doğrudan destek vardır. ²⁴

En güvenli bootstrap yaklaşımı: App Configuration connection string yerine **Entra ID / managed identity** ile bağlanmak ve uygulamaya sadece endpoint URL vermek (endpoint URL “secret” sayılmadığı için görece güvenlidir). ²⁵

Uygulamaların sırları “ihtiyacı kadar” alması (least privilege)

Uygulama içi erişim modeli:

- Her workload (API, worker, device-gateway, CI pipeline) için ayrı identity
- Her identity’ye sadece gerekli Key Vault rolü
- Human admin erişimi: mümkünse JIT/PIM ve ayrı admin grubu (RBAC bu modelle uyumludur)

²⁶

CI/CD, denetim ve operasyon

GitHub Actions → Azure: OIDC (şifresiz) yaklaşımı

Key Vault ile CI/CD entegre ederken, GitHub Actions’ın OIDC ile Azure’a bağlanması; “repo secret olarak uzun ömürlü şifre koyma” riskini azaltır. Microsoft’un GitHub Actions + Key Vault örneği OIDC akışıyla secret çekmeyi gösterir. ²⁷ Ayrıca GitHub dokümantasyonu; `id-token: write` izninin yalnız OIDC token istemek için olduğunu ve tek başına kaynaklara yazma yetkisi vermediğini açıklar. ²⁸

Azure Login Action projesi; OIDC kullanımını “increased security” gerekçesiyle önerir ve loglara hassas çıktı düşmemesi için uyarılar içerir. ²⁹

App Service üzerinde Key Vault Reference (kod değişmeden)

App Service/Functions tarafında app setting değerini `@Microsoft.KeyVault(...)` formatıyla bağlayarak, uygulama kodu “normal env var okur gibi” devam edebilir. ³⁰

Rotasyon davranışı kritik: secret version belirtilmezse “latest” kullanılır; yeni versiyon geldiğinde App Service cache nedeniyle **24 saat içinde** güncellenir; ayrıca bir config değişikliği app restart ile hemen refresh tetikleyebilir. ²⁰

Audit ve loglar: “varsayılan olarak toplanmıyor” kabulüyle ilerle

Azure Monitor tarafında Key Vault resource log’ları **diagnostic setting** oluşturulana kadar toplanıp saklanmaz; “route etmezsen yoktur” yaklaşımı geçerlidir. ³¹ Key Vault günlüklerini etkinleştirmek için `AuditEvent` kategorisini açıp Log Analytics/Storage/Event Hub’a yönlendirme adımları Microsoft dokümanında örnek CLI komutuyla da verilir. ³²

Silinmeye dayanıklılık: soft delete + purge protection

Key Vault recovery özellikleri; soft delete’ın “geri dönüşüm kutusu” gibi çalıştığını, purge protection’ın ise retention süresi dolmadan kalıcı silmeyi engellediğini anlatır ve üretimde güçlü şekilde önerir. ³³

Rotation: key, secret, certificate

- Key rotation policy ayarları (expiry, rotate interval, Event Grid notification) Microsoft dokümanında detaylıdır. ³⁴
- Secret autorotation; Event Grid + Azure Functions ile kurgulanabilir. ³⁵

Performans ve limitler: tasarımı rate limit’e göre yap

Key Vault’un işlem limitleri vardır (ör. “other transactions” için 10 saniyede 4.000 gibi) ve throttling ihtimali göz önüne alınmalıdır. ³⁶ Bu yüzden: - Uygulamada local cache (sürelili)

- App Service Key Vault reference cache davranışı

- App Configuration üzerinden config çekip secret’ları sınırlı sayıda resolve etmek (Key Vault secret fetch “tek tek” olur) ³⁷

Slack/Notion/Drive/Linear/Figma/GitHub proje zemin standardı

Aşağıdaki iskelet; çok proje/çok ürün yönetiminde “her yerde aynı ritim” için tasarlanmıştır:

- `Entity["company","GitHub","code hosting platform"]`
- Repo şablonu: `README`, `docs/adr`, `docs/security`, `/.github/workflows`, `/.github/ISSUE_TEMPLATE`, `/.github/PULL_REQUEST_TEMPLATE`
- Contract deposu: `contracts/openapi` veya `contracts/proto` (tek doğruluk kaynağı) ⁹
- `Entity["company","Notion","workspace software"]`: “Product OS”
- DB’ler: `Initiatives`, `Epics`, `Risks`, `Experiments`, `Release Notes`, `Secrets Inventory` (sadece metadata)
- `Entity["company","Slack","collaboration platform"]`: `#proj-{appId}`, `#proj-{appId}-dev`, `#proj-{appId}-ops`, `#proj-{appId}-design`
- `Entity["company","Linear","issue tracking tool"]`
- Labels: `area:device`, `area:mobile`, `area:web`, `area:backend`, `type:security`, `type:experiment`, `prio:p0..p3`

- Entity["company","Figma","design tool company"]
- Sayfalar: 01-Foundations, 02-Components, 03-Flows, 04-Design QA, 05-Release
- Entity["company","Monday.com","work management platform"]
- Operasyonel board: "İçerik üretimi / kampanya / sosyal etki operasyonu"
- Entity["company","Adobe","software company"]
- Brand kit export (ikon setleri, görsel şablonlar)

Bu katmanın "sır" ile ilişkisi: proje araçlarında asla secret tutulmaz; yalnız "secret owner, rotation tarihi, hangi sistem kullanıyor" gibi metadata tutulur. ³⁸

ESP32 ile üç yapay zekâ ürünü: şema, dizin, kod mantığı ve ürünleşme

Neden ESP32 + "edge AI" gerçekçi?

Entity["company","Espressif Systems","esp32 chip vendor"]'in resmi framework'ü ESP-IDF; ESP32 serisi için C/C++ tabanlı SDK'dır ve çok sayıda IoT üründe kullanılır. ³⁹

TensorFlow Lite Micro'nun ESP32 üzerinde çalışabildiği ve yerel (cihaz üstü) inference senaryolarını açtığı Espressif tarafından duyurulmuştur. ⁴⁰ Ayrıca esp-tflite-micro projesi; ESP-NN optimizasyonlarıyla "person detection" gibi örneklerde ciddi hızlanma ölçümleri paylaşır. ⁴¹

Entity["company","Edge Impulse","edge ai platform"] ESP32 üzerinde C++ kütüphanesi olarak model deploy edip cihazda sınıflandırma çalıştırma akışını dokümente eder. ⁴² Geliştirme aracı olarak Entity["company","PlatformIO","embedded dev platform"] ESP-IDF projelerine out-of-the-box destek verir. ⁴³

Aşağıdaki 3 proje; "mahremiyet", "satın alınabilir değer" ve "insan hayatına dokunma" kriterleriyle kurgulanmıştır. Not: Sağlık iddiası/teşhis sunmaz; "risk skoru/erken uyarı/yaşam kolaylaştırma" düzeyinde tasarlanır.

Proje A: Sessiz Yardım Bilekliği (offline keyword spotting + acil durum akışı)

Problem: Panik, saldırı, ani sağlık krizi gibi durumlarda kişi konuşamaz/telefonu açamaz.

Çözüm: Bileklik; kısa bir "tetik cümle"yi (ör. "yardım") ya da belirli bir tıklama ritmini algılayıp telefona BLE ile "panic event" yollar; telefon otomatik arama/SMS/konum paylaşımı yapar.

AI: Keyword spotting (KWS) — mikrofon verisinden sınıflandırma. Edge AI tarafında KWS, ESP32 üzerinde gerçek zamanlı senaryolara uygundur; Edge Impulse + ESP-NN hızlandırma yaklaşımıyla bu tür kullanım örnekleri vardır. ⁴⁴

Donanım blokları:

- ESP32 (tercihen S3 sınıfı), mikrofon (I2S), IMU (düşme/çarpma algısı), titreşim motoru, küçük LiPo + şarj devresi.

Firmware mantığı (durum makinesi): - IDLE → LISTEN (mikrofon buffer)

- INFER (KWS modeli)
- CONFIRM (false-positive azaltmak için 2 aşamalı doğrulama: ses + buton/gesture)
- ALERT (BLE üzerinden signed event + timestamp)
- COOLDOWN (olay fırtınasını engelle)

Minimal dizin önerisi (monorepo içinde): - `devices/silent-help-band/firmware/` (ESP-IDF)

- `devices/silent-help-band/model/` (dataset, training, quantization)
- `apps/mobile/` (BLE bağlanma + acil akış)
- `services/event-gateway/` (opsiyonel: push/notify)

Gizlilik: Ham ses kaydı saklanmaz; yalnız “embedding/feature” geçici tutulur; olay logları cihazda minimal. (Bu yaklaşım, “cihaz üstü inference” motivasyonu ile uyumludur.) 40

Proje B: Kişisel Tetikleyici Skoru (hava kalitesi + semptom günlüğü → kişiselleştirilmiş uyarı)

Problem: Astım/alerji/baş ağrısı/uyku kalitesi gibi durumlar; hava kalitesi (PM/VOC), nem, sıcaklık, CO2 gibi çevresel tetikleyicilerle ilişkilidir; fakat kişiden kişiye değişir.

Çözüm: Cepte taşınan sensör modülü + mobil uygulama; çevre verisini toplar, kullanıcı günlükleriyle eşleştirir ve kişiye özel “risk skoru” üretir.

Pazar sinyali: Sağlık & fitness uygulama pazarı büyüyor; özellikle “medical tracking” alt türünde 2024’te ciddi download artışı raporlanmıştır. 45

AI yaklaşımı (pratik): - İlk faz: kurallı skor + basit regresyon

- Sonra: kişiselleştirilmiş zaman serisi modeli (telefon üzerinde)

Bu sayede ESP32 yalnız “sensor hub” olur, ağır model telefon tarafına kayar.

Teknik akış: - ESP32 → BLE/Wi-Fi ile ölçüm paketleri

- Mobil → zaman damgası + kullanıcı girişi

- Backend → anonimleştirilmiş analiz (opsiyonel)

Not: Config/feature flag; App Configuration’da, sırlar Key Vault’ta tutulur. 46

Proje C: Mahremiyetli Ev İçi Güvenlik/Yaşam Belirtisi Monitörü (person detection + “olay” odaklı)

Problem: Yalnız yaşayan yaşlılar/engelliler için “düşme / uzun süre hareketsizlik” gibi risklerde erken uyarı ihtiyacı.

Çözüm: Kamera görüntüsünü kaydetmeyen, düşük çözünürlük/cihaz üstü “person presence” çıkaran bir cihaz; yalnızca “olay” üretir (ör. 2 saattir hareket yok).

Neden mümkün? `esp-tflite-micro` tarafında “person detection” örneği ve ESP-NN hızlandırması ile S3 üzerinde ciddi performans iyileşmesi ölçülmüş durumda. 41

Donanım: - ESP32-CAM (OV2640 + PSRAM gibi özelliklerle gelen modüller yaygındır) 47

- Güç yönetimi (uyku modları)

- Opsiyonel: PIR + IMU (kamera yerine sensörle doğrulama)

Mahremiyet kuralı: - Görüntü saklama yok; sadece “presence score / motion vector / event timestamp” sakla.

- Uzak erişim gerekiyorsa, yalnız event gönder.

Ürünleşme: - Aile üyelerine “ben iyiyim” durumu

- Sosyal girişim tarafında düşük maliyetli paket + abonelik (opsiyonel)

Web uygulamalarını mobile taşıma: PWA, TWA, WebView seçenekleri ve ihtiyaç listesi

Seçeneklerin teknik gerçekliği

PWA (Progressive Web App): - Install edilebilirlik için; HTTPS + Web App Manifest gibi kriterler vardır. Web.dev; manifest'in gerekli alanlarını (name/icons/start_url/display vb.) ve install kriterlerini detaylandırır. ⁴⁸

- MDN, PWA install edilebilirlik rehberinde benzer minimum gereksinimleri açıklar. ⁴⁹

- iOS tarafında web push: iOS/iPadOS 16.4 ile "Home Screen web app"lere Web Push desteği geldi; izin isteme kullanıcı etkileşimiyle tetiklenmeli ve bildirimler sistem bildirimleriyle entegre çalışır. Bu, WebKit tarafından net biçimde dokümente edilmiştir. ⁵⁰

TWA (Trusted Web Activity): - Android'de web içeriğini tarayıcı motoru içinde fullscreen sunar; host app'in cookie/localStorage gibi web state'e doğrudan erişimi yoktur. ⁵¹

Bu, "sadece web uygulamam var ama store'da görünmek istiyorum" senaryolarında WebView'a daha güvenli bir alternatif olabilir.

WebView wrapper: - Hızlıdır ama güvenlik borcu doğurur. `Entity["organization","OWASP","web security project"]`; WebView'lerde JavaScript'in gereksizse kapatılmasını önerir; aksi halde XSS, veri sızması ve `addJavascriptInterface` gibi köprülerle RCE riskleri artar. ⁵²

- Android resmi dokümanı; native bridge risklerini (origin doğrulama zorluğu vb.) vurgular. ⁵³

En çok ihtiyaç duyulan "web → mobil" senaryo türleri

Talep sinyali için uygulama pazarında 2024–2025 döneminde: - Küresel app harcamalarının yükseldiği, zaman geçirmenin arttığı ve AI tarafında ivmenin güçlendiği; `Entity["company","Sensor Tower","app market intelligence"]` rapor özetlerinde öne çıkıyor. ⁵⁴

- Sağlık/fitness ve özellikle "medical tracking" gibi alt segmentlerde büyüme görülüyor. ⁴⁵

Bu sinyallerden yola çıkarak (web'den mobile geçişte) en çok karşılaşılan ihtiyaçlar: - İç sistem panelleri (CRM/ERP/dashboard) → mobil erişim (çoğu zaman PWA yeterli)

- Eğitim/kurumsal içerik portalı → offline okuma + push (PWA + iOS home screen modeli) ⁵⁵

- AI asistan/üretkenlik araçları → mobil-first (AI kategorisinde büyüme metrikleri raporlanıyor) ⁵⁴

- Sağlık takip/günlükleme → sensör/cihaz entegrasyonu (PWA sınırlı kalır; native/bileşen gerekebilir) ⁴⁵

Yapım süreci (PWA odaklı "en hızlı değer" akışı)

1) Web uygulamayı PWA kriterlerine yaklaştır: manifest + HTTPS + offline stratejisi. ⁵⁶

2) iOS push gerekiyorsa: "home screen web app" şartlarını ve kullanıcı etkileşimi kuralını tasarıma yerleştir. ⁵⁰

3) Android store presence gerekiyorsa: WebView yerine TWA düşün (daha güvenli runtime ve modern tarayıcı güncellemeleri). ⁵⁷

4) WebView kaçınılmazsa: OWASP/Android guidance doğrultusunda JS/bridge yüzeyini minimumda tut. ⁵⁸

5) Sırlar ve kimlikler: Key Vault + Entra ID + App Configuration standardına bağla (yukarıdaki bölüm). ⁵⁹

Derinleştirilecek araştırma başlıkları ve hazır promptlar

Aşağıdaki konular; her proje için “tasarımdan üretime” geçerken genelde kritik boşluklar yaratır. Bu boşlukları kapatmak için doğrudan kullanılabilir promptlar:

Sır envanteri ve erişim matrisi

Prompt:

“Key Vault + App Configuration + Entra ID kullanarak `dev/staging/prod` ortamlarında, `app/service/device/ci` workload'ları için least-privilege erişim matrisi çıkar. Her workload için: identity tipi, gereken roller, secret isimleri, rotation planı, audit log'lar, incident response adımları üret.”

Dayanak ilkeler: RBAC önerisi, legacy access policies uyarısı, least privilege. 60

ESP32 ürünlerinde model seçimi ve ölçüm planı

Prompt:

“ESP32-S3 üzerinde TinyML için (keyword spotting / person detection / time-series) 3 farklı model ailesi öner. Her model için: quantization stratejisi, RAM/flash tahmini, latency hedefi, test dataseti, false-positive minimizasyonu, OTA güncelleme riskleri ve kabul kriterleri yaz.”

Dayanak: ESP32'de TFLite Micro ve optimize inference gerçekliği. 61

Web → mobil karar ağacı

Prompt:

“Şu web uygulamanın özellikleri: (push gerekli mi? offline gerekli mi? native sensor/ble gerekli mi? store dağıtımı şart mı? güvenlik seviyesi?) Buna göre PWA/TWA/WebView/native seçeneklerini puanlayan bir karar ağacı üret; her seçenekte riskleri ve mitigasyonları listele.”

Dayanak: PWA install kriterleri, iOS web push koşulları, WebView riskleri, TWA özellikleri. 62

OAuth/OIDC token yönetimi (platform anahtarları)

Prompt:

“Üçüncü parti servis entegrasyonlarında (OAuth 2.0) access token/refresh token saklama ve rotasyon stratejisi tasarla. Refresh token'ın confidentiality gereklilikleri, mobil client riskleri, backend token exchange yaklaşımı ve Key Vault/App Configuration'a nasıl bağlanacağı konusunda net bir mimari çıkar.”

Dayanak: OAuth 2.0 refresh token tanımı ve güvenlik hassasiyeti. 63

1 8 The Twelve-Factor App

https://12factor.net/config?utm_source=chatgpt.com

2 allenap.me – 12 Factor App: Config in the environment is bad advice

https://allenap.me/posts/12-factor-app-config-in-the-environment-is-bad-advice?utm_source=chatgpt.com

3 9 What is OpenAPI? – OpenAPI Initiative

https://www.openapis.org/what-is-openapi?utm_source=chatgpt.com

4 Introduction to gRPC | gRPC

https://grpc.io/docs/what-is-grpc/introduction/?utm_source=chatgpt.com

5 least privilege - Glossary | CSRC

https://csrc.nist.gov/glossary/term/least_privilege?utm_source=chatgpt.com

6 Introduction to the Standard Directory Layout – Maven

https://maven.apache.org/guides/introduction/introduction-to-the-standard-directory-layout.html?utm_source=chatgpt.com

7 Externalized Configuration :: Spring Boot

https://docs.spring.io/spring-boot/reference/features/external-config.html?utm_source=chatgpt.com

10 JSON Schema - Specification [#section]

https://json-schema.org/specification?utm_source=chatgpt.com

11 About Azure Key Vault secrets - Azure Key Vault | Azure Docs

https://docs.azure.cn/en-us/key-vault/secrets/about-secrets?utm_source=chatgpt.com

12 14 38 46 59 Secure your Azure Key Vault secrets | Microsoft Learn

https://learn.microsoft.com/en-us/azure/key-vault/secrets/secrets-best-practices?utm_source=chatgpt.com

13 24 Developers Guide for using Spring Cloud Azure App Configuration - Java on Azure | Microsoft Learn

https://learn.microsoft.com/en-us/azure/developer/java/spring-framework/app-configuration-support?utm_source=chatgpt.com

15 Managed identities for Azure resources - Managed identities for Azure resources | Microsoft Learn

https://learn.microsoft.com/en-us/entra/identity/managed-identities-azure-resources/overview?utm_source=chatgpt.com

16 Secretless authentication in Azure - Managed identities for Azure resources | Microsoft Learn

https://learn.microsoft.com/en-us/entra/identity/managed-identities-azure-resources/secretless-authentication?utm_source=chatgpt.com

17 26 60 Secure your Azure Key Vault | Azure Docs

https://docs.azure.cn/en-us/key-vault/general/security-recommendations?utm_source=chatgpt.com

18 Azure role-based access control (Azure RBAC) vs. access policies | Microsoft Learn

https://learn.microsoft.com/en-us/azure/key-vault/general/rbac-access-policy?utm_source=chatgpt.com

19 22 Grant permission to applications to access an Azure key vault using Azure RBAC | Microsoft Learn

https://learn.microsoft.com/en-us/azure/key-vault/general/rbac-guide?utm_source=chatgpt.com

20 30 Use Key Vault References as App Settings - Azure App Service | Microsoft Learn

https://learn.microsoft.com/en-us/azure/app-service/app-service-key-vault-references?utm_source=chatgpt.com

21 Configure network security for Azure Key Vault | Microsoft Learn

https://learn.microsoft.com/en-us/azure/key-vault/general/network-security?utm_source=chatgpt.com

23 Understand feature management using Azure App Configuration | Microsoft Learn

https://learn.microsoft.com/en-us/azure/app-configuration/concept-feature-management?utm_source=chatgpt.com

- 25 **Azure App Configuration best practices | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/azure-app-configuration/howto-best-practices?utm_source=chatgpt.com
- 27 **Use Azure Key Vault secrets in a GitHub Actions workflow | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/developer/github/github-actions-key-vault?utm_source=chatgpt.com
- 28 **Configuring OpenID Connect in Azure - GitHub Docs**
https://docs.github.com/en/actions/security-for-github-actions/security-hardening-your-deployments/configuring-openid-connect-in-azure?apiVersion=2022-11-28&utm_source=chatgpt.com
- 29 **GitHub - Azure/login: Connect to Azure**
https://github.com/Azure/login?utm_source=chatgpt.com
- 31 **Monitor Azure Key Vault | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/key-vault/general/monitor-key-vault?utm_source=chatgpt.com
- 32 **Azure Key Vault günlüklerini etkinleştir | Microsoft Learn**
https://learn.microsoft.com/tr-tr/azure/key-vault/general/howto-logging?utm_source=chatgpt.com
- 33 **Azure Key Vault recovery overview | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/key-vault/general/key-vault-recovery?utm_source=chatgpt.com
- 34 **Configure cryptographic key auto-rotation in Azure Key Vault | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/key-vault/keys/how-to-configure-key-rotation?utm_source=chatgpt.com
- 35 **Understanding autorotation in Azure Key Vault | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/key-vault/general/autorotation?utm_source=chatgpt.com
- 36 **Azure Key Vault service limits | Microsoft Learn**
https://learn.microsoft.com/en-us/azure/key-vault/general/service-limits?utm_source=chatgpt.com
- 37 **Spring Cloud Azure App Configuration**
https://microsoft.github.io/spring-cloud-azure/docs/azure-app-configuration/2.6.0/reference/html/index.html?utm_source=chatgpt.com
- 39 **ESP IoT Development Framework | Espressif Systems**
https://www.espressif.com/en/products/sdks/esp-idf?utm_source=chatgpt.com
- 40 61 **Announcing TensorFlow Lite Micro Support on ESP32 | Espressif Systems**
https://www.espressif.com/en/news/TensorFlow_blogpost?utm_source=chatgpt.com
- 41 **GitHub - espressif/esp-tflite-micro: TensorFlow Lite Micro for Espressif Chipsets**
https://github.com/espressif/esp-tflite-micro?utm_source=chatgpt.com
- 42 **Run C++ library on Espressif ESP-EYE (ESP32) - Edge Impulse Documentation**
https://docs.edgeimpulse.com/docs/run-inference/cpp-library/running-your-impulse-esp32?utm_source=chatgpt.com
- 43 **Espressif IoT Development Framework — PlatformIO latest documentation**
https://docs.platformio.org/en/latest/frameworks/espidf.html?utm_source=chatgpt.com
- 44 **Edge Impulse Announces Official Espressif ESP32 Support, Releases Open Source ESP-EYE Firmware - Hackster.io**
https://www.hackster.io/news/edge-impulse-announces-official-espressif-esp32-support-releases-open-source-esp-eye-firmware-b626af54d66e?utm_source=chatgpt.com
- 45 **State of Mobile Health & Fitness Apps 2025**
https://sensortower.com/blog/state-of-mobile-health-and-fitness-in-2025?utm_source=chatgpt.com
- 47 **ESP32-CAM Camera Module | OpenELAB Wiki**
https://wiki.openelab.io/esp/esp32-cam-camera-module?utm_source=chatgpt.com

48 56 62 What does it take to be installable? | web.dev

https://web.dev/articles/install-criteria?utm_source=chatgpt.com

49 Making PWAs installable - Progressive web apps | MDN

https://developer.mozilla.org/en-US/docs/Web/Progressive_web_apps/Guides/Making_PWAs_installable?utm_source=chatgpt.com

50 55 Web Push for Web Apps on iOS and iPadOS | WebKit

https://webkit.org/blog/13878/web-push-for-web-apps-on-ios-and-ipados/?utm_source=chatgpt.com

51 57 Overview | Web on Android | Chrome for Developers

https://developer.chrome.com/docs/android/trusted-web-activity?utm_source=chatgpt.com

52 58 MASTG-BEST-0012: Disable JavaScript in WebViews - OWASP Mobile Application Security

https://mas.owasp.org/MASTG/best-practices/MASTG-BEST-0012/?utm_source=chatgpt.com

53 WebView – Native bridges | Security | Android Developers

https://developer.android.com/privacy-and-security/risks/insecure-webview-native-bridges?utm_source=chatgpt.com

54 Sensor Tower: Consumer Spending on Apps Soared in 2024 and Mobile Rode the Wave of AI Enthusiasm

https://www.prnewswire.com/news-releases/sensor-tower-consumer-spending-on-apps-soared-in-2024-and-mobile-rode-the-wave-of-ai-enthusiasm-302356449.html?utm_source=chatgpt.com

63 RFC 6749 - The OAuth 2.0 Authorization Framework

https://datatracker.ietf.org/doc/html/rfc6749?utm_source=chatgpt.com